

Data Risk Assessment Report 2024

Company A - Saudi Arabian Government Healthcare Entity

Document Control

Field	Details
Document Title	Data Risk Assessment Report 2024
Document ID	RISK-ASSESS-2024-001
Version	2.0
Classification	CONFIDENTIAL - INTERNAL USE ONLY
Owner	Risk Management Committee
Author	Abdullah Al-Mutairi (Chief Risk Officer)
Review Date	August 15, 2024
Next Review	February 15, 2025 (Semi-Annual)
Methodology	ISO 31000:2018 Risk Management Guidelines
Approved By	Dr. Khalid Al-Dosari (Chief Executive Officer)
Approval Date	August 22, 2024
Distribution	Executive Leadership, Risk Committee, Board of Dir

Version History

Version	Date	Author	Changes
1.0	February 2024	Abdullah Al-Mutairi	Initial risk assessment for 2024
1.5	May 2024	Noura Al-Shahrani	Mid-year update: added ransomware risk
2.0	August 2024	Abdullah Al-Mutairi	Full reassessment with updated risk scores

Approval Signatures

Role	Name	Signature	Date
Chief Executive Officer	Dr. Khalid Al-Dosari	Digitally Signed	Aug 22, 2024
Chief Risk Officer	Abdullah Al-Mutairi	Digitally Signed	Aug 15, 2024
Chief Information Security Officer	Fahad Al-Ghamdi	Digitally Signed	Aug 16, 2024

Chief Data Officer	Ahmed Al-Rashid	Digitally Signed	Aug 16, 2024
Board Risk Committee Chair	Dr. Sara Al-Mutlaq	Digitally Signed	Aug 22, 2024

Table of Contents

1. Executive Summary 4

2. Introduction & Scope 6

- 2.1 Purpose

- 2.2 Scope and Boundaries

- 2.3 Methodology (ISO 31000)

3. Organizational Context 8

- 3.1 Company Overview

- 3.2 Data Assets Inventory

- 3.3 Regulatory Environment

4. Risk Assessment Methodology 11

- 4.1 Risk Identification Process

- 4.2 Risk Analysis Framework

- 4.3 Risk Evaluation Criteria

5. Risk Assessment Results 15

- 5.1 Overall Risk Profile

- 5.2 Detailed Risk Register (27 Risks)

- 5.3 Risk Heatmap Analysis

6. Critical & High Risks (Detailed Analysis) 28

- 6.1 R-01: Ransomware Attack on Patient Database

- 6.2 R-03: Vendor Data Breach (Supply Chain Risk)

- 6.3 R-04: PDPL Non-Compliance Fine

- 6.4 R-07: Insider Threat (Privileged User)

- 6.5 R-12: Epic EHR System Outage

7. Risk Treatment Plans 36

8. Residual Risk Analysis 42

9. Monitoring & Review Plan 44

10. Appendices 46

- Appendix A: Risk Matrix & Scoring Criteria

- Appendix B: Risk Register Summary Table

- Appendix C: Comparison with Feb 2024 Assessment

- Appendix D: Board Risk Appetite Statement

1. Executive Summary

1.1 Assessment Overview

This Data Risk Assessment Report provides a comprehensive evaluation of data-related risks facing Company A as of August 2024. The assessment was conducted in accordance with ISO 31000:2018 risk management standards and covers all data assets, systems, and processes across our 47 clinics, 5 hospitals, and central data infrastructure.

Key Highlights:

- 27 data risks identified and assessed
- 2 CRITICAL risks requiring immediate executive attention
- 6 HIGH risks with active mitigation plans in progress
- Overall residual risk profile: Within Board-approved risk appetite
- Investment in controls: SAR 14.2 million allocated for 2024-2025

1.2 Risk Profile Summary

Risk Rating	Count	% of Total	Change vs Feb 2024
CRITICAL (Score 15-25)	2	7.4%	↑ 1 (Ransomware risk escalated)
HIGH (Score 10-14)	6	22.2%	↓ 2 (Mitigations effective)
MEDIUM (Score 5-9)	13	48.1%	↑ 1
LOW (Score 1-4)	6	22.2%	No change
TOTAL	27	100%	—

1.3 Top 5 Critical & High Risks

Rank	Risk ID	Risk Description	Score	Rating	Trend
1	R-01	Ransomware attack encrypting patient database	20	CRITICAL	↑
2	R-07	Insider threat: Privileged user data exfiltration	15	CRITICAL	↔
3	R-03	Vendor data breach (supply chain risk)	12	HIGH	↔
4	R-12	Epic EHR system outage (business continuity)	11	HIGH	↓
5	R-04	PDPL non-compliance regulatory fine	10	HIGH	↓

1.4 Executive Recommendations

IMMEDIATE ACTIONS (Next 30 Days):

1. Ransomware Defense (R-01): Implement immutable backups using AWS S3 Object Lock for all Tier-1 data assets (Budget: SAR 450,000) — PRIORITY 1
2. Insider Threat Detection (R-07): Deploy Varonis DatAdvantage for privileged user activity monitoring (Budget: SAR 380,000) — PRIORITY 2
3. Vendor Security Audits (R-03): Conduct mandatory on-site security assessments for 8 critical vendors (Microsoft, Oracle, SAP, etc.) — PRIORITY 3

STRATEGIC INITIATIVES (Next 90-180 Days):

4. Establish 24/7 Security Operations Center (SOC) with dedicated data breach response team
5. Purchase cyber insurance policy with minimum SAR 50 million coverage for ransomware/data breach incidents
6. Implement Data Loss Prevention (DLP) solution across all endpoints and email gateways

Investment Required: SAR 8.7 million (already approved in 2024 Risk Budget)

1.5 Residual Risk Statement

After accounting for existing controls and planned mitigations, the residual data risk exposure is estimated at SAR 12.4 million (maximum potential loss from all risks combined). This is within the Board's approved risk appetite of SAR 15 million for data-related risks.

Risk Management Committee Recommendation: The current risk profile is ACCEPTABLE provided that the 3 immediate actions listed above are completed by October 31, 2024.

Prepared by: Abdullah Al-Mutairi, Chief Risk Officer

Reviewed by: Risk Management Committee (August 15, 2024)

Approved by: Dr. Khalid Al-Dosari, CEO (August 22, 2024)

2. Introduction & Scope

2.1 Purpose

This Data Risk Assessment Report serves to:

1. Identify all material data-related risks facing Company A
2. Assess the likelihood and impact of each risk using quantitative and qualitative methods
3. Prioritize risks based on their severity and potential business impact
4. Recommend treatment strategies to reduce risks to acceptable levels
5. Comply with NDMO Domain 10 (Risk Management) and ISO 31000 standards
6. Inform executive decision-making and resource allocation for data security investments

2.2 Scope and Boundaries

IN SCOPE:

- All data systems and databases (Epic EHR, Oracle EBS, SAP, Salesforce, custom applications)
- Patient data and personal health information (PHI)
- Financial and administrative data
- Data processing activities by 3rd-party vendors and partners
- Cloud infrastructure (AWS, Azure)
- Data centers and physical storage
- Data governance processes and controls

OUT OF SCOPE:

- Non-data IT risks (e.g., hardware failures, network outages not affecting data)
- Physical security risks unrelated to data theft
- Operational risks not directly impacting data integrity, confidentiality, or availability
- Strategic business risks (market competition, regulatory changes beyond PDPL)

Assessment Period: January 1, 2024 – August 15, 2024

2.3 Methodology (ISO 31000:2018)

This assessment follows the ISO 31000:2018 Risk Management framework:

Step 1: Establish Context

- Review organizational objectives and data governance framework
- Define risk criteria (likelihood scales, impact scales, risk appetite)

Step 2: Risk Identification

- Workshops with 24 stakeholders (IT, Security, Legal, Clinical Operations, DMO)
- Review of incident logs and near-miss events from 2023-2024
- Analysis of industry threat intelligence (Healthcare ISAC reports, SANS data breach reports)
- Regulatory compliance gap analysis (NDMO, PDPL, NCA ECC)

Step 3: Risk Analysis

- Likelihood assessment (1-5 scale): Based on historical frequency, threat intelligence, control effectiveness
- Impact assessment (1-5 scale): Based on financial loss, regulatory fines, reputational damage, patient safety
- Inherent risk score = Likelihood × Impact (before controls)
- Residual risk score = Adjusted for existing control effectiveness

Step 4: Risk Evaluation

- Compare risks against Board-approved risk appetite
- Prioritize risks for treatment based on severity and cost-benefit analysis

Step 5: Risk Treatment

- Develop mitigation plans for HIGH and CRITICAL risks
- Assign risk owners and target completion dates

Step 6: Monitoring & Review

- Quarterly risk register updates
- Semi-annual comprehensive reassessment

3. Organizational Context

3.1 Company Overview

Company A is a Saudi Arabian government-owned healthcare provider operating:

- 5 hospitals (total capacity: 1,240 beds)
- 47 outpatient clinics across Riyadh, Jeddah, and Dammam
- 850 employees (185 physicians, 340 nurses, 95 IT/data staff, 230 administrative staff)
- Annual patient visits: 1.2 million outpatient visits, 48,000 inpatient admissions

Data Assets:

- 18.5 million patient records in Epic EHR system
- 450,000 health insurance claims processed annually (Oracle EBS)
- 2.4 TB of medical imaging data (PACS system - Philips IntelliSpace)
- 12 years of historical data (2012-2024)

3.2 Data Assets Inventory

System	Data Type	Criticality	Volume	Vendor/Platform
Epic EHR	Patient health records, clinical notes	CRITICAL	18.5M records	Epic Systems (Cloud-hosted)
Oracle EBS	Financial, billing, claims	HIGH	450K claims/year	Oracle (On-premise)
SAP HR	Employee data, payroll	HIGH	850 employees	SAP SuccessFactors (Cloud)
Philips PACS	Medical imaging (X-ray, MRI, CT scans)	CRITICAL	2.4 TB	Philips IntelliSpace (Hybrid)
Salesforce CRM	Patient inquiries, marketing	MEDIUM	85,000 contacts	Salesforce Health Cloud
Laboratory System	Lab test results	CRITICAL	2.1M tests/year	Roche CoaguChek
Pharmacy System	Prescription records	CRITICAL	1.8M prescriptions	McKesson Pharmacy
Data Warehouse	Analytics, reporting (Informatica)	HIGH	12 TB total	AWS Redshift

3.3 Regulatory Environment

Company A operates under multiple regulatory frameworks:

- PDPL (Personal Data Protection Law) - Royal Decree M/19 (2021)
 - Maximum fine: SAR 5,000,000 for serious violations
 - Mandatory breach notification within 72 hours
- NDMO (National Data Management Office) - 191 controls across 15 domains
 - Annual compliance audit required
 - Non-compliance may result in loss of government contracts
- NCA Essential Cybersecurity Controls (ECC)
 - 114 controls for critical infrastructure
 - Healthcare entities classified as "essential services"
- Ministry of Health Regulations
 - Patient data retention: Minimum 10 years
 - Medical imaging retention: 7 years

Compliance Status (as of August 2024):

- PDPL Compliance: 94.2%
- NDMO Compliance: 92.4%
- NCA ECC Compliance: 88.7%

4. Risk Assessment Methodology

4.1 Risk Identification Process

Data Sources:

1. Stakeholder Workshops (June 10-12, 2024): 24 participants from IT, Security, Legal, Clinical Operations, DMO
2. Incident Log Review: Analysis of 47 security incidents and 12 data quality incidents from 2023-2024
3. Threat Intelligence: Healthcare ISAC advisories, SANS top 20 critical controls, CVE database for Epic/Oracle
4. Regulatory Gap Analysis: NDMO audit findings, PDPL compliance assessment results
5. Vendor Risk Assessments: Security questionnaires from 18 data processors
6. Previous Risk Assessment: Comparison with February 2024 report to identify emerging risks

Risk Categories:

- Cybersecurity Risks (ransomware, hacking, DDoS)
- Data Privacy Risks (unauthorized access, PDPL violations)
- Operational Risks (human error, system failures)
- Third-Party Risks (vendor breaches, cloud provider outages)
- Compliance Risks (regulatory fines, audit failures)
- Data Quality Risks (corruption, integrity loss)

4.2 Risk Analysis Framework

Likelihood Scale (L):

Score	Level	Description	Frequency
5	Almost Certain	Expected to occur in most circumstances	> 1 per year
4	Likely	Will probably occur in most circumstances	1 per 1-3 years
3	Possible	Might occur at some time	1 per 3-5 years
2	Unlikely	Could occur but not expected	1 per 5-10 years
1	Rare	May occur only in exceptional circumstances	1 per 10 years

Impact Scale (I):

Score	Level	Financial Loss	Regulatory Fine	Reputational Damage	Patient Safety
5	Catastrophic	> SAR 10M	> SAR 5M	National media, loss of government contracts	Multiple patient deaths
4	Major	SAR 5M - 10M	SAR 1M - 5M	Regional media, significant reputational harm	Serious patient harm

3	Moderate	SAR 1M - 5M	SAR 500K - 1M	Local media coverage	Minor patient harm
2	Minor	SAR 100K - 1M	SAR 50K - 500K	Social media complaints	No patient harm
1	Insignificant	< SAR 100K	< SAR 50K	Minimal public awareness	No impact

Risk Score Matrix:

Risk Score = Likelihood (L) × Impact (I)

Score Range	Risk Rating	Action Required
15 - 25	CRITICAL	Immediate action; executive escalation; monthly mo
10 - 14	HIGH	Action plan required within 30 days; quarterly mon
5 - 9	MEDIUM	Action plan within 90 days; annual monitoring
1 - 4	LOW	Accept risk or monitor; no immediate action

4.3 Risk Evaluation Criteria

Board Risk Appetite Statement (Approved June 2024):

Company A has a LOW risk appetite for data-related risks that could:

- Compromise patient safety or privacy
- Result in PDPL or NDMO regulatory fines > SAR 1 million
- Cause loss of government healthcare contracts
- Lead to national media coverage of data breaches

Acceptable Residual Risk Threshold:

- Total residual risk exposure: ≤ SAR 15 million
- No individual CRITICAL risks (score 15+) may remain unmitigated beyond 60 days
- HIGH risks must have documented treatment plans approved by the Risk Committee

5. Risk Assessment Results

5.1 Overall Risk Profile

Risk Distribution by Rating:

CRITICAL (2 risks): ■■■ 7.4%
HIGH (6 risks): ■■■■■■ 22.2%
MEDIUM (13 risks): ■■■■■■■■■■■■■■ 48.1%
LOW (6 risks): ■■■■■■ 22.2%

Risk Distribution by Category:

Risk Category	CRITICAL	HIGH	MEDIUM	LOW	Total
Cybersecurity	2	2	4	1	9
Data Privacy	0	2	3	2	7
Operational	0	1	3	2	6
Third-Party/Vendor	0	1	2	1	4
Compliance	0	0	1	0	1
TOTAL	2	6	13	6	27

Top Risk Owners:

Risk Owner	# of Risks Assigned	Total Risk Score
Chief Information Security Officer (CISO)	11	98
Chief Data Officer (CDO)	7	52
IT Operations Manager	5	31
Chief Privacy Officer	4	24

5.2 Detailed Risk Register (27 Risks)

CRITICAL RISKS (Score 15-25)

Risk R-01: Ransomware Attack on Patient Database

Field	Details
Risk ID	R-01
Category	Cybersecurity
Description	Ransomware malware encrypts Epic EHR patient datab
Likelihood	4 (Likely) - Healthcare is #1 target for ransomwar
Impact	5 (Catastrophic) - Complete loss of patient care c
Inherent Risk Score	20 (CRITICAL)
Existing Controls	- Daily backups to AWS S3 - Endpoint antivirus
Control Effectiveness	60% effective (backups not immutable; can be encry
Residual Risk Score	20 (CRITICAL) - Controls insufficient
Risk Owner	Fahad Al-Ghamdi (CISO)
Treatment Plan	IMMEDIATE (30 days): 1. Implement AWS S3 Object

Target Completion	October 31, 2024
Status	■ IN PROGRESS (Budget approved; vendor contracts s

Risk R-07: Insider Threat - Privileged User Data Exfiltration

Field	Details
Risk ID	R-07
Category	Cybersecurity
Description	Malicious or compromised privileged user (database
Likelihood	3 (Possible) - 1 incident per 3-5 years industry a
Impact	5 (Catastrophic) - PDPL fine SAR 5M + reputational
Inherent Risk Score	15 (CRITICAL)
Existing Controls	- Background checks for privileged users - Quar
Control Effectiveness	40% effective (audit logs reviewed only monthly; n
Residual Risk Score	15 (CRITICAL)
Risk Owner	Fahad Al-Ghamdi (CISO)
Treatment Plan	IMMEDIATE (30 days): 1. Deploy Varonis DatAdvan
Target Completion	October 31, 2024
Status	■ IN PROGRESS (Varonis POC completed; budget appro

HIGH RISKS (Score 10-14)

Risk R-03: Vendor Data Breach (Supply Chain Risk)

Field	Details
Risk ID	R-03
Category	Third-Party/Vendor
Description	One of Company A's 18 data processors (Epic, Oracl
Likelihood	3 (Possible)
Impact	4 (Major) - Company A liable under PDPL Article 22
Inherent Risk Score	12 (HIGH)
Existing Controls	- Data Processing Agreements (DPAs) with all 18 ve
Control Effectiveness	50% effective (questionnaires not verified; no on-
Residual Risk Score	12 (HIGH)

Risk Owner	Noura Al-Shahrani (Procurement Director)
Treatment Plan	Next 90 days: 1. Conduct on-site security audit
Target Completion	November 30, 2024
Status	■ PLANNED (Budget approved; audits scheduled for S

Risk R-04: PDPL Non-Compliance Regulatory Fine

Field	Details
Risk ID	R-04
Category	Compliance
Description	SDAIA (Saudi Data & AI Authority) conducts PDPL co
Likelihood	2 (Unlikely) - Current PDPL compliance: 94.2%; no
Impact	5 (Catastrophic) - Maximum fine SAR 5M + mandatory
Inherent Risk Score	10 (HIGH)
Existing Controls	- Quarterly PDPL compliance audits (internal) -
Control Effectiveness	70% effective
Residual Risk Score	10 (HIGH)
Risk Owner	Layla Al-Harbi (Chief Privacy Officer / DPO)
Treatment Plan	Next 90 days: 1. Remediate 12 remaining PDPL ga
Target Completion	November 30, 2024
Status	■ PLANNED (Gap remediation 60% complete)

Risk R-12: Epic EHR System Outage (Business Continuity)

Field	Details
Risk ID	R-12
Category	Operational
Description	Epic EHR system suffers extended outage (> 4 hours
Likelihood	3 (Possible) - Epic had 2 global outages in 2023 (
Impact	4 (Major) - Patient care disruption; estimated SAR
Inherent Risk Score	12 (HIGH)
Existing Controls	- Epic High Availability architecture (99.9% SLA)<
Control Effectiveness	65% effective (failover not tested in 12 months; d
Residual Risk Score	12 (HIGH)

Risk Owner	Mohammed Al-Otaibi (IT Operations Manager)
Treatment Plan	Next 60 days: 1. Conduct Epic failover test (ta
Target Completion	October 15, 2024
Status	■ PLANNED (Failover test scheduled for Sept 20)

Risk R-08: Phishing Attack Leading to Account Takeover

Field	Details
Risk ID	R-08
Category	Cybersecurity
Description	Employee clicks phishing email; attacker steals cr
Likelihood	4 (Likely) - 23 phishing incidents reported in 202
Impact	3 (Moderate) - Limited data exposure (attacker has
Inherent Risk Score	12 (HIGH)
Existing Controls	- Proofpoint email filtering (blocks 99.2% of phis
Control Effectiveness	75% effective
Residual Risk Score	10 (HIGH)
Risk Owner	Fahad Al-Ghamdi (CISO)
Treatment Plan	Next 90 days: 1. Implement hardware-based MFA (
Target Completion	November 30, 2024
Status	■ PLANNED

Risk R-15: Cloud Provider Outage (AWS/Azure)

Field	Details
Risk ID	R-15
Category	Third-Party/Vendor
Description	AWS or Azure suffers region-wide outage affecting
Likelihood	2 (Unlikely) - AWS had 3 major outages in 2023; Az
Impact	5 (Catastrophic) - Epic EHR unavailable; patient c
Inherent Risk Score	10 (HIGH)
Existing Controls	- Multi-region architecture (Primary: AWS eu-centr
Control Effectiveness	80% effective
Residual Risk Score	10 (HIGH)

Risk Owner	Mohammed Al-Otaibi (IT Operations Manager)
Treatment Plan	ACCEPT RISK - Residual risk acceptable given multi
Target Completion	N/A
Status	■ ACCEPTED

Risk R-22: Data Corruption in Database Migration

Field	Details
Risk ID	R-22
Category	Operational
Description	Planned Oracle EBS database upgrade (scheduled Q1
Likelihood	2 (Unlikely)
Impact	5 (Catastrophic) - Loss of billing data could resu
Inherent Risk Score	10 (HIGH)
Existing Controls	- Full database backup before migration - Oracl
Control Effectiveness	85% effective
Residual Risk Score	10 (HIGH)
Risk Owner	Ahmed Al-Rashid (CDO)
Treatment Plan	Next 120 days (before Q1 2025 migration): 1. Co
Target Completion	December 31, 2024
Status	■ PLANNED

MEDIUM RISKS (Score 5-9) — 13 Risks

(Summarized for brevity; full details available in Appendix B)

ID	Risk Description	L	I	Score	Owner	Status
R-02	Accidental deletion of data by privileged user	4	4	8	IT Ops Manager	■ Mitigation planned
R-05	DDoS attack on patient portal website	3	3	9	CISO	■ Mitigated (Cloudflare)
R-06	Unauthorized access via stolen laptop	3	3	9	CISO	■ Mitigation in progress
R-09	SQL injection vulnerability in custom apps	4	4	8	CDO	■ Code review ongoing
R-10	Unpatched vulnerabilities in Epic/Oracle	3	3	9	IT Ops	■ Patch mgmt improved
R-11	Insufficient disaster recovery testing	3	3	6	IT Ops	■ DR test scheduled Q4
R-13	Privacy breach via patient portal	3	3	6	CPO	■ Mitigated (MFA)
R-14	Lack of encryption for data in transit	4	4	8	CISO	■ TLS 1.3 deployment

R-16	GDPR violation (EU patient data)	5	5	CPO	■ GDPR DPA signed
R-18	Data quality issues (duplicate records)	2	6	CDO	■ Data profiling ongoing
R-20	Missing audit trails for data access	3	6	CISO	■ SIEM upgrade planned
R-23	IoT medical device vulnerabilities	4	8	CISO	■ Assessment in Q4
R-25	Lack of data anonymization for analytics	3	6	CDO	■ Anonymization tools

LOW RISKS (Score 1-4) — 6 Risks

(Summarized; full details in Appendix B)

ID	Risk Description	L	I	Score	Owner	Status
R-17	Physical theft of backup tapes	3	3	3	IT Ops	■ ACCEPTED
R-19	Data retention policy violations	2	2	4	Legal	■ Policy updated
R-21	Inadequate staff training on PDPL	2	2	4	HR	■ Training plan Q4
R-24	Vendor lock-in (Epic EHR)	4	4	4	CDO	■ ACCEPTED
R-26	Lack of open data publication	1	1	2	CDO	■ ACCEPTED
R-27	Shadow IT (unapproved SaaS apps)	2	2	4	CISO	■ Discovery scan Q4

5.3 Risk Heatmap Analysis

Risk Heatmap (Likelihood vs Impact):

IMPACT →

	R-04 R-15	R-01 R-07
	R-22	
R-02	R-03 R-12	
R-09 R-14 R-23		
R-11 R-13	R-05 R-06	
R-18 R-20	R-10	
R-25		
R-19 R-21 R-27		
R-26	R-17	R-16 R-24

+-----
1 2 3 4 5
← LIKELIHOOD

Legend:

- RED ZONE (CRITICAL): R-01, R-07 — Immediate action required
- ORANGE ZONE (HIGH): R-03, R-04, R-08, R-12, R-15, R-22 — Action plans in progress
- YELLOW ZONE (MEDIUM): 13 risks — Monitor and plan mitigations
- GREEN ZONE (LOW): 6 risks — Accept or minimal controls

6. Critical & High Risks (Detailed Analysis)

6.1 Risk R-01: Ransomware Attack on Patient Database

Threat Scenario:

1. Attack Vector: Phishing email with malicious attachment sent to 150 employees
2. Initial Compromise: 1 user clicks attachment; malware downloads Cobalt Strike beacon
3. Lateral Movement: Attacker escalates privileges, compromises domain admin account
4. Data Encryption: Ransomware (LockBit 3.0) encrypts Epic EHR database, backups, and file servers
5. Ransom Demand: SAR 15 million demanded; 72-hour deadline

Business Impact Analysis:

- Patient Care Disruption: All 47 clinics and 5 hospitals unable to access patient records
- Estimated Downtime: 7-14 days (if ransom not paid; restore from backups)
- Revenue Loss: SAR 3.2M per day × 10 days = SAR 32M
- PDPL Fine: Mandatory breach notification; potential SAR 5M fine (Article 30)
- Reputational Damage: National media coverage; loss of patient trust; potential loss of government contracts
- Recovery Cost: SAR 8M (forensic investigation, system rebuild, Epic re-implementation)

Total Estimated Loss: SAR 45 million

Current Control Gaps:

1. Backups Not Immutable: AWS S3 backups can be deleted/encrypted by attacker with compromised credentials
2. No Ransomware Detection: CrowdStrike EDR not configured for ransomware-specific behavioral detection
3. Insufficient Network Segmentation: Epic EHR servers can communicate directly with internet (outbound traffic not restricted)

Treatment Plan (Approved Budget: SAR 1.35M):

Action	Description	Cost	Owner	Due Date
1. AWS S3 Object Lock	Enable immutable backups (WORM) for all Tier-1 data	SAR 450,000	CISO	Sept 30
2. Darktrace AI	Deploy AI-based ransomware detection on Epic servers	SAR 620,000	CISO	Oct 15
3. Network Segmentation	Isolate Epic EHR from internet; restrict outbound traffic	SAR 280,000	IT Ops	Oct 31

Expected Outcome:

- Residual risk score reduced from 20 (CRITICAL) to 8 (MEDIUM)
- Estimated loss reduced from SAR 45M to SAR 5M (faster recovery with immutable backups)

6.2 Risk R-03: Vendor Data Breach (Supply Chain Risk)

Threat Scenario:

1. Vendor Compromise: Epic Systems (EHR vendor) suffers data breach due to unpatched vulnerability
2. Data Exposure: Attacker gains access to Company A's patient data hosted on Epic's cloud
3. Breach Notification: Epic notifies Company A 48 hours after discovery
4. Company A Liability: Under PDPL Article 22, Company A is liable for vendor's breach

Real-World Examples:

- 2023: Nuance Communications (Microsoft) breach exposed healthcare data from 42 hospital clients
- 2022: OneTouchPoint vendor breach exposed 2.65M patient records from multiple hospitals

Business Impact:

- PDPL Fine: SAR 2M (Company A failed to ensure vendor had adequate security controls)
- Notification Cost: SAR 180,000 (notify 18.5M patients via mail/email/SMS)
- Credit Monitoring: SAR 450,000 (offer 1-year credit monitoring to affected patients)
- Legal Fees: SAR 320,000 (defend against class-action lawsuits)
- Reputational Damage: Loss of patient trust; negative media coverage

Total Estimated Loss: SAR 3 million

Current Control Gaps:

1. No On-Site Vendor Audits: Security questionnaires not verified; no independent validation
2. No Continuous Monitoring: Vendor security posture unknown between annual questionnaires
3. Weak DPA Breach Clauses: Breach notification SLA is 7 days (industry best practice: 24 hours)

Treatment Plan (Approved Budget: SAR 420K):

Action	Description	Cost	Owner	Due Date
1. On-Site Audits	Conduct SOC 2 Type II audits for Epic and vendor	SAR 120,000	Procurement	Nov 30
2. BitSight Monitoring	Continuous vendor cybersecurity scanning	SAR 180,000/year	CISO	Oct 15
3. DPA Updates	Add 24-hour breach notification SLA to all DPAs	SLA to all DPAs	Legal	Sept 30

Expected Outcome:

- Residual risk score reduced from 12 (HIGH) to 6 (MEDIUM)
- Early warning of vendor security issues enables proactive mitigation

(Sections 6.3, 6.4, 6.5 continue with similar detailed analysis for R-04, R-07, R-12...)

7. Risk Treatment Plans

7.1 Treatment Strategy Summary

Company A employs a 4-tiered risk treatment strategy aligned with ISO 31000:

- 1. MITIGATE (Reduce): Implement controls to reduce likelihood or impact (used for 20 risks)
- 2. AVOID (Eliminate): Discontinue the risky activity (used for 1 risk: R-26 shadow IT apps banned)
- 3. TRANSFER (Share): Use insurance or contractual risk transfer (used for 3 risks: cyber insurance, vendor indemnification)
- 4. ACCEPT (Retain): Accept residual risk within appetite (used for 3 risks: R-17, R-24, R-26)

7.2 Mitigation Budget Summary

Total Approved Risk Mitigation Budget (2024-2025): SAR 8.7 million

Risk Category	# Risks	Budget Allocated	% of Total
Cybersecurity	9	SAR 5.2M	59.8%
Data Privacy (PDPL)	7	SAR 1.8M	20.7%
Operational	6	SAR 980,000	11.3%
Third-Party/Vendor	4	SAR 720,000	8.3%
TOTAL	27	SAR 8.7M	100%

Investment Priority:

- 1. Ransomware Defense (R-01): SAR 1.35M (15.5% of budget) — HIGHEST PRIORITY
- 2. Insider Threat Detection (R-07): SAR 1.04M (12.0%)
- 3. Phishing Protection (R-08): SAR 320,000 (3.7%)
- 4. Epic EHR Business Continuity (R-12): SAR 753,000 (8.7%)
- 5. Vendor Risk Management (R-03): SAR 420,000 (4.8%)

7.3 Implementation Timeline

Q3 2024 (Sept):

- AWS S3 Object Lock implementation (R-01)
- Vendor DPA updates (R-03)
- Epic failover test (R-12)

Q4 2024 (Oct-Dec):

- Darktrace ransomware detection deployment (R-01)
- Varonis privileged user monitoring (R-07)

- On-site vendor audits (R-03)
- PDPL gap remediation (R-04)

Q1 2025 (Jan-Mar):

- Hardware MFA rollout (R-08)
- Oracle EBS migration (R-22)
- IoT medical device security assessment (R-23)

8. Residual Risk Analysis

8.1 Residual Risk Summary (After Mitigations)

Current Inherent Risk Exposure: SAR 82.4 million (sum of all 27 risks' worst-case losses)

Residual Risk Exposure (After Controls): SAR 12.4 million

Risk Reduction: 85% reduction in total risk exposure

Residual Risk by Rating:

Rating	Current (Aug 2024)	After Mitigations (Q1 2025)	Change
CRITICAL (15-25)	2 risks	0 risks	-2 ■
HIGH (10-14)	6 risks	2 risks	-4 ■
MEDIUM (5-9)	13 risks	18 risks	+5
LOW (1-4)	6 risks	7 risks	+1
TOTAL	27 risks	27 risks	—

8.2 Comparison with Board Risk Appetite

Board-Approved Risk Appetite: ≤ SAR 15 million total residual risk exposure

Current Residual Risk: SAR 12.4 million

Status: ■ WITHIN APPETITE (17% headroom)

Key Performance Indicators (KPIs):

KPI	Target	Current	Status
CRITICAL risks	0	2	■ OVERDUE (to be resolved by Oct 31)
HIGH risks	≤ 3	6	■ IN PROGRESS (reduction to 2 by Q1 2025)
Risk mitigation budget utilization	≥ 80%	62%	■ ON TRACK (contracts signed; deployment in progress)

Residual risk exposure	≤ SAR 15M	SAR 12.4M	■ COMPLIANT
------------------------	-----------	-----------	-------------

9. Monitoring & Review Plan

9.1 Risk Monitoring Cadence

Activity	Frequency	Owner	Participants
Risk Register Updates	Monthly	Risk Manager	Risk owners
Risk Committee Meeting	Quarterly	CRO	CEO, CISO, CDO, CFO, Legal
Board Risk Report	Quarterly	CRO	Board of Directors
Comprehensive Risk Reassessment	Semi-Annual	CRO	All stakeholders (24 participants)
Emerging Risk Scan	Monthly	CISO	Threat intelligence team

9.2 Risk Reporting Dashboard

Monthly KPI Dashboard (Sent to Executive Leadership):

- 1. Risk Profile Summary: Distribution by rating (CRITICAL/HIGH/MEDIUM/LOW)
- 2. Top 5 Risks: Current score, trend (↑ ↓ ↔), mitigation status
- 3. Mitigation Progress: % complete for each treatment plan
- 4. Budget Utilization: Actual spend vs approved budget
- 5. New & Emerging Risks: Identified in past 30 days

9.3 Escalation Triggers

Automatic Escalation to CEO/Board:

- 1. New CRITICAL risk identified (score 15+)
- 2. Any risk increases by ≥ 5 points in a single quarter
- 3. Residual risk exposure exceeds SAR 15M
- 4. Material data breach incident occurs
- 5. Regulatory fine > SAR 500,000 imposed

10. Appendices

Appendix A: Risk Matrix & Scoring Criteria

Risk Scoring Matrix:

	Impact →	1 (Insignificant)	2 (Minor)	3 (Moderate)	4 (Major)	5 (Catastrophic)
↓ Likelihood						
5 (Almost Certain)		5	10	15	20	25
4 (Likely)		4	8	12	16	20
3 (Possible)		3	6	9	12	15
2 (Unlikely)		2	4	6	8	10
1 (Rare)		1	2	3	4	5

- Color Legend:
- RED (15-25): CRITICAL — Immediate action required
 - ORANGE (10-14): HIGH — Action plan within 30 days
 - YELLOW (5-9): MEDIUM — Action plan within 90 days
 - GREEN (1-4): LOW — Accept or monitor

Appendix B: Risk Register Summary Table

(Full risk register available as Excel export: Risk_Register_2024_Q3.xlsx)

ID	Risk Description	Category	L	I	Score	Rating	Owner	Status
R-01	Ransomware attack	Cybersecurity	4	5	20	CRITICAL	CISO	■
R-07	Insider threat	Cybersecurity	3	5	15	CRITICAL	CISO	■
R-03	Vendor breach	3rd-Party	3	4	12	HIGH	Procurement	■
R-04	PDPL fine	Compliance	2	5	10	HIGH	CPO	■
R-08	Phishing	Cybersecurity	4	3	12	HIGH	CISO	■
R-12	Epic outage	Operational	3	4	12	HIGH	IT Ops	■
R-15	Cloud outage	3rd-Party	2	5	10	HIGH	IT Ops	■
R-22	Migration failure	Operational	2	5	10	HIGH	CDO	■
(18 additional medium/low risks...)								

Appendix C: Comparison with Feb 2024 Assessment

Risk Score Changes (Feb 2024 → Aug 2024):

Risk ID	Risk Description	Feb Score	Aug Score	Change	Reason
R-01	Ransomware	12	20	↑ +8	Industry threat increase; 5 Saudi hospit

R-04	PDPL fine	12	10	↓ -2	Compliance improved from 88% to 94.2
R-12	Epic outage	15	12	↓ -3	Epic upgraded to HA architecture
R-10	Unpatched systems	12	9	↓ -3	Automated patch management impleme

Summary: 1 risk escalated to CRITICAL (R-01); 3 risks reduced due to effective mitigations.

Appendix D: Board Risk Appetite Statement

Approved by Board of Directors: June 18, 2024

Company A's Board of Directors has approved the following Risk Appetite Statement for data-related risks:

OVERALL APPETITE: LOW — Company A has a low appetite for data-related risks that could:

- Compromise patient safety or privacy
- Result in regulatory fines > SAR 1 million
- Cause national media coverage or reputational damage
- Lead to loss of government healthcare contracts

QUANTITATIVE THRESHOLDS:

Metric	Threshold	Action if Exceeded
Total residual risk exposure	≤ SAR 15 million	Immediate Board review; additional mitigation budg
Number of CRITICAL risks	0	CEO must approve acceptance; mitigation plan withi
Number of HIGH risks	≤ 3	Quarterly Board reporting; mitigation plans requir
Annual cybersecurity budget	≥ 5% of IT budget	Increase budget if risk profile deteriorates

RISK-TAKING BOUNDARIES:

- NO appetite for:
 - Storing patient data without encryption
 - Sharing patient data with 3rd parties without DPAs
 - Non-compliance with PDPL or NDMO regulations
- LIMITED appetite for:
 - Vendor risks (must have SOC 2 Type II certification)
 - Cloud adoption (only AWS/Azure with multi-region HA)
- MODERATE appetite for:
 - Innovative data analytics projects (with privacy safeguards)
 - AI/ML for clinical decision support (with human oversight)

END OF REPORT

Document Approval:

Approver	Signature	Date
Dr. Khalid Al-Dosari, CEO	Digitally Signed	August 22, 2024
Abdullah Al-Mutairi, CRO	Digitally Signed	August 15, 2024
Dr. Sara Al-Mutlaq, Board Risk Committee Chair	Digitally Signed	August 22, 2024

Next Review Date: February 15, 2025

Distribution List:

- Executive Leadership Team
- Board of Directors
- Risk Management Committee
- CISO, CDO, CPO
- Internal Audit
- External Auditors (PwC)

This document is classified as CONFIDENTIAL. Unauthorized disclosure may result in regulatory fines and reputational damage.

Company A - Protecting Patient Data, Enabling Better Healthcare